

Поиск следов компрометации в ОС Linux

Цели

- 1 Определить, где могут быть следы компрометации
- 2 Узнать, какие логи необходимо собирать в первую очередь
- 3 Инструменты для работы с инцидентом
- 4 Составление таймлайна

Готовьтесь заранее

Основа быстрого и эффективного расследования и поиска следов компрометации:

- все инструменты «под рукой»
- у сотрудников выстроен чёткий алгоритм действий:
 - что делать
 - как делать
 - что собирать
 - куда отправлять

Сбор информации

С помощью специализированных дистрибутивов (режим forensic mode):

- Kali
- CAINE
- Paladin
- Helix
- Rip Linux
- DEFT Linux

С помощью инструментов:

- FTK Imager
- dd

Например, побитовая копия диска с помощью встроенного в любой линукс dd:

fdisk -l —находим нужный диск(колонка device)

dd if=<source> of=<destination> bs=<byte size>

dd if=/dev/sda1 of=/dev/sdb3 bs=512 noerror

Флаг noerror добавляете, чтобы программа не останавливала работу из-за побитых секторов.

Сбор информации

Рекомендуется снять:

- образ оперативной памяти до перезагрузки хоста
- дамп оперативной памяти можно с помощью следующих утилит
 - Lime
 - Linux Memory Grabber
 - Rekall

Снятие дампа оперативной памяти через rekall:

```
cd rekall/tools/linux/
```

```
make
```

```
sudo insmod pmem.ko
```

```
sudo lsmod
```

```
dd if=/dev/pmem of=forensic_RAM_image.raw
```

```
rmmod pmem
```


Timeline

Временные метки Linux:

- время последней модификации
- время последнего доступа (чтения)
- последнее изменение статуса
- время удаления
- время создания

Важно! В файловых системах ext2 и ext3 нет временной метки о времени создания файла.

Отметка времени о создании введена в ext4.

Создать timeline можно с помощью инструмента log2timeline.py

```
sudo log2timeline.py -z Etc/Gmt -t / -p linux timeline_file mount_disk
```

Создание таймлайна займёт некоторое время.

Проведение аудита рисков

Поиск паролей:

```
grep --color=auto -rnw '/' -ie "PASSWORD" --color=always 2> /dev/null
```

и/или

```
find . -type f -exec grep -i -l "PASSWORD" {} /dev/null \;
```

```
locate password | more
```

Поиск ssh-ключей:

```
find / -name authorized_keys 2> /dev/null
```

```
find / -name id_rsa 2> /dev/null
```

```
└─$ find -type f -exec grep -i -l "PASSWORD" {} /dev/null \;  
./local/lib/python2.7/site-packages/pip/_vendor/six.py: MovedAttribute("HTTPPasswordMgr", "urllib2", "urllib.request"),  
./local/lib/python2.7/site-packages/pip/_vendor/six.py: MovedAttribute("HTTPPasswordMgrWithDefaultRealm", "urllib2", "urllib.request"),  
./local/lib/python2.7/site-packages/pip/_vendor/urllib3/connection.py: key_password=None,  
./local/lib/python2.7/site-packages/pip/_vendor/urllib3/connection.py: self.key_password = key_password  
./local/lib/python2.7/site-packages/pip/_vendor/urllib3/connection.py: key_password=None,  
./local/lib/python2.7/site-packages/pip/_vendor/urllib3/connection.py: self.key_password = key_password  
./local/lib/python2.7/site-packages/pip/_vendor/urllib3/connection.py: key_password=self.key_password,  
./local/lib/python2.7/site-packages/pip/_vendor/urllib3/connectionpool.py: ``ca_cert_dir``, ``ssl_version``, ``key_password`` are only used if :mod:`ssl`  
./local/lib/python2.7/site-packages/pip/_vendor/urllib3/connectionpool.py: key_password=None,  
./local/lib/python2.7/site-packages/pip/_vendor/urllib3/connectionpool.py: self.key_password = key_password
```

```
└─$ locate password | more  
/boot/grub/i386-pc/legacy_password_test.mod  
/boot/grub/i386-pc/password.mod  
/boot/grub/i386-pc/password_pbkdf2.mod  
/etc/cryptsetup-ntfs-passwd  
/etc/pam.d/common-password
```

Проведение аудита рисков

LinPEAS — это скрипт, который ищет возможные пути для повышения привилегий на хостах Linux/Unix*/MacOS

<https://raw.githubusercontent.com/carlospolop/privilege-escalation-awesome-scripts-suite/master/linPEAS/linpeas.sh>

Или можно загрузить сразу в образ, через который исследуете:

```
wget "https://raw.githubusercontent.com/carlospolop/privilege-escalation-awesome-scripts-suite/master/linPEAS/linpeas.sh" -O linpeas.sh
```

`./linpeas.sh -a` — полная глубокая проверка

`./linpeas.sh -s` — более лёгкая проверка. На диск ничего не записывается

`./linpeas.sh -P` — можно передать пароль для `sudo` пользователя или любого другого пользователя по которым, например, ходил злоумышленник

LinuxSmartEnumaration <https://raw.githubusercontent.com/diego-treitos/linux-smart-enumeration/master/lse.sh>

У него уже 2 режима:

`./lse.sh -l1` — соберёт информацию

`./lse.sh -l2` — сделает дамп всей собранной информации

Работа с пользователями группами

Просматриваете все УЗ:

```
cat /etc/passwd
```

Проверяете атрибуты УЗ:

```
passwd -S USER_NAME
```

Проверяете временных пользователей:

```
find / -nouser -print
```

Проверяете используемые группы:

```
cat /etc/group
```

```
cat /etc/sudoers
```

Ищете файлы с UID 0

```
grep :0: /etc/passwd
```

```
$ grep :0: /etc/passwd
root:x:0:0:root:/root:/usr/bin/zsh
```

```
$ sudo cat /etc/sudoers
[sudo] password for [redacted]:
#
# This file MUST be edited with the 'visudo' command as root.
#
# Please consider adding local content in /etc/sudoers.d/ instead of
# directly modifying this file.
#
# See the man page for details on how to write a sudoers file.
#
Defaults    env_reset
Defaults    mail_badpass
Defaults    secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin"
Defaults    use_pty
```

Скриншоты спикера Алины Кальсберг

Пользовательская активность

Поиск недавно открытых / модифицированных / изменённых файлов пользователем с помощью find за 7 дней:

```
find . -type f -atime -7 -printf “%AY%Am%Ad%AH%AM%AS %h/%s/%f\n” -user <username>|sort -n
```

```
find . -type f -mtime -7 -printf “%TY%Tm%Td%TH%TM%TS %h — %s — %f\n” -user <username>|sort -n
```

```
find . -type f -ctime -7 -printf “%CY%Cm%Cd%CH%CM%CS %h — %s — %f\n” -user <username>|sort -n
```

Проверка запущенных процессов и истории выполнения команд:

```
cat ~/.bash_history
```

```
cat /root/.bash_history
```

Выполненные команды через sudo можно посмотреть в auth.log

Поиск исполняемых файлов, к которым обращался пользователь за 7 дней

```
find . -type f -perm /111 -user thole -atime -7 -printf “%AY%Am%Ad%AH%AM%AS %h — %s — %f\n” -user <username>| sort -n
```

Проверка неизвестного монтирования

```
cat /proc/mounts
```

Исследование журналов Linux

Большинство журналов Linux хранятся в папке /var/log/.

Интересны следующие журналы:

/var/log/auth.log

/var/log/deamon.log

/var/log/syslog или /var/log/messages(для Centos)

lastlog

/var/log/wtmp

/var/log/btmp

Другие журналы в зависимости от назначения сервера, например, apache2, httpd, samba, MySQL и т. д.

```
ls -la /var/log
total 1740
drwxr-xr-x 21 root root      4096 Aug 16 16:19 .
drwxr-xr-x 12 root root      4096 Mar 29  2021 ..
-rw-r--r--  1 root root         0 Mar 19 15:45 alternatives.log
-rw-r--r--  1 root root        244 Feb  1  2022 alternatives.log.1
-rw-r--r--  1 root root       1817 Jan 12  2022 alternatives.log.2.gz
-rw-r--r--  1 root root       2734 Jan 10  2022 alternatives.log.3.gz
-rw-r--r--  1 root root       3040 Jun 30  2021 alternatives.log.4.gz
-rw-r--r--  1 root root       6473 Apr 11  2021 alternatives.log.5.gz
drwxr-xr-x  2 root adm        4096 Mar 19 15:45 apache2
drwxr-xr-x  2 root root        4096 Mar 19 15:45 apt
-rw-r----- 1 root adm       2843 Aug 16 16:39 auth.log
-rw-r----- 1 root adm     24449 Aug 16 16:18 auth.log.1
-rw-r----- 1 root adm       1631 Apr 27 09:15 auth.log.2.gz
-rw-r----- 1 root adm       1886 Apr 23 11:25 auth.log.3.gz
-rw-r----- 1 root adm       2089 Apr 23 07:27 auth.log.4.gz
-rw-r----- 1 root adm      10760 Aug 16 16:10 boot.log
```

Скриншот спикера Алины Кальсберг

Проверка конфигурации системы

Просмотр файлов конфигурации для настройки сети:

```
cat /etc/network/interfaces
```

```
cat /etc/resolve.conf
```

```
cat /etc/dnsmasq.conf
```

Информация об используемой ОС и системе в целом:

```
cat /etc/os-release
```

```
cat /etc/hostname
```

```
cat /etc/timezone
```

Проверка конфигурации DNS

```
cat /etc/resolve.conf
```

Правила firewall:

```
iptables -L -n
```

```
$ cat /etc/os-release
PRETTY_NAME="Kali GNU/Linux Rolling"
NAME="Kali GNU/Linux"
ID=kali
VERSION="2021.4"
VERSION_ID="2021.4"
VERSION_CODENAME="kali-rolling"
ID_LIKE=debian
ANSI_COLOR="1;31"
HOME_URL="https://www.kali.org/"
SUPPORT_URL="https://forums.kali.org/"
BUG_REPORT_URL="https://bugs.kali.org/"
```

```
$ cat /etc/network/interfaces
# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

source /etc/network/interfaces.d/*

# The loopback network interface
auto lo
iface lo inet loopback
```

Скриншоты спикера Алины Кальсберг

Следы закрепления

Просмотр запущенных сервисов:

```
sudo service --status-all
```

Проверка процессов:

```
top
```

```
ps aux
```

```
lsof -p [pid]
```

Запланированные задания:

```
cat /etc/crontab
```

Сетевые подключения:

```
netstat -narp
```

```
$ sudo service --status-all
[ - ] apache-htcacheclean
[ - ] apache2
[ - ] apparmor
[ - ] atftpd
[ - ] avahi-daemon
[ + ] binfo-support
```

```
$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
```

Скриншоты спикера Алины Кальсберг

Инструменты для работы с инцидентом

Для работы с дампом диска:

AutoPsy

FtkImager

Для работы с памятью:

Volatility

Rekall

Дополнительные инструменты:

LinPEAS

LinuxSmartEnumeration

И любые другие инструменты, которые удобно использовать.



Скриншот спикера Алины Кальсберг

Вывод

Вы узнали:

- где могут быть следы компрометации
- какие логи необходимо собирать в первую очередь
- где может закрепиться злоумышленник
- как построить таймлайн-системы
- как проверить слабые места
- какие инструменты для расследования можно использовать